

Jean Victor Borges de Abreu

Análise da Transição para Algoritmos criptográficos Pós-Quânticos nos modelos NIST

Petrópolis -Rio de Janeiro

2026

Jean Victor Borges de Abreu

Análise da Transição para Algoritmos criptográficos Pós-Quânticos nos modelos NIST

Trabalho de Conclusão de Curso apresentado
à

FACULDADE DE EDUCAÇÃO TECNOLÓGICA DO ESTADO DO RIO DE JANEIRO
FAETERJ/PETRÓPOLIS

Orientador: Nome do Orientador

Petrópolis -Rio de Janeiro
2026

1 Resumo

2 Abstract

3 Lista de Abreviaturas

ABNT: Associação Brasileira de Normas Técnicas CSPRNG: Cryptographically Secure Pseudo Random Number Generator DRBG: Deterministic Random Bit Generator FAETERJ: Faculdade de Educação Tecnológica do Estado do Rio de Janeiro JEP: JDK Enhancement Proposals KEM: Key Encapsulation Mechanism LCG: Linear Congruential Generator LWE: Learning With Errors ML-KEM: Module-Lattice-Based Key Encapsulation Mechanism NIST: National Institute of Standards and Technology NRBG: Non-deterministic Random Bit Generator PQC: Post-Quantum Cryptography PRNG: Pseudo Random Number Generator QRNG: Quantum Random Number Generator TRNG: True Random Number Generator

Sumário

1	RESUMO	2
2	ABSTRACT	3
3	LISTA DE ABREVIATURAS	4
	Sumário	4
4	INTRODUÇÃO	7
4.1	Contextualização do Tema	7
4.2	Justificativa/Problema de Pesquisa	7
4.3	Motivação/Hipótese e Ameaça Tecnológica	7
4.4	Objetivos	7
4.5	Metodologia	7
5	FUNDAMENTOS DA ALEATORIEDADE EM COMPUTAÇÃO	8
5.1	Entropia e Fontes de Incerteza	8
5.2	A Semente (Seed) como Elemento Crítico	9
5.3	Definição de Aleatoriedade e Tipos de Geradores Aleatórios	10
5.4	Avaliação Estatística da Aleatoriedade	11
6	QUEBRA DE CRIPTOGRAFIAS	14
6.1	Visão Geral da Quebra de Criptografias	14
6.2	Falhas Históricas de Aleatoriedade	14

6.2.1	Uma avaliação pratica do Dual_EC_DRBG	15
6.3	Vulnerabilidades em Algoritmos Criptográficos	20
7	REVISÃO DOS PROTOCOLOS E PADRÕES DE CRIPTOGRAFIA	22
7.1	Fundamentação da Autoridade e Tipos de Padrões	22
7.1.1	NIST Internal/Interagency Reports (NISTIR)	22
7.1.2	FIPS	22
7.1.2.1	FIPS 204 (ML-DSA)	23
7.1.2.2	FIPS 205 (SLH-DSA)	23
7.1.3	SPs	23
7.1.3.1	FISMA e OMB	24
7.1.3.2	NIST SP 800–53	24
7.2	Metodologia de Seleção	25
7.2.1	Fases de Competição	25
7.3	Manutenção e Substituição de Padrões	25
7.3.1	Ciclo de Vida e Retirada (Withdrawal)	25
8	PLANEJAMENTO PARA A CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)	27
8.1	Contextualização e Gestão de Risco	27
8.1.1	A Ameaça Quântica e o Paradigma “Harvest Now, Decrypt Later”	27
8.1.2	Mapeamento do Risco Quântico	27
8.2	Inventário e Descoberta Criptográfica	30
8.2.1	Estratégias de Descoberta em Redes e Sistemas	30
8.2.2	Adoção do CBOM (Cryptographic Bill of Materials)	30
8.3	Agilidade Criptográfica e Novos Padrões	30
8.3.1	Conceitos de Agilidade e Desafios de Desempenho	30
8.3.2	Os Padrões Pós-Quânticos Finais	30
8.4	Estratégias de Migração e Hibridização	31
8.4.1	Hibridização (Criptografia Clássica e PQC)	31
8.4.2	Assinaturas Baseadas em Hash para Adoção Imediata	31
8.5	Roadmap e Manutenção da Base Criptográfica	31
8.5.1	Cronograma e Descontinuação de Algoritmos Atuais	31
8.5.2	O Papel Contínuo da Entropia	31
9	NIST IR 8547 TRANSIÇÃO PARA A CRIPTOGRAFIA PÓS- QUÂNTICA: ESTRATÉGIAS E CONSIDERAÇÕES	32
9.1	Urgencia Prática e o Modelo de Ameaça	32
9.1.1	Ameaça Harvest now, Decrypt Later	32
9.1.2	Teorema de Mosca e a Linha do Tempo	32

9.2	Novos Padrões e Categorias de Segurança	32
9.2.1	Publicações dos primeiros FIPS PQC	33
9.2.2	Categorias de Segurança Pós-Quântica (1 a 5)	33
9.3	Cronograma de Descontinuação (Deprecation)	33
9.3.1	Transição de Assinaturas Digitais (RSA, ECDSA, EdDSA)	33
9.3.2	Transição de Estabelecimento de Chaves (DH, MQV, RSA)	34
9.4	Estratégias de Transição: Protocolos Híbridos	34
9.4.1	Soluções Híbridas (PQC-Classical)	34
9.4.2	Protocolos Híbridos (TLS, SSH, IPsec)	34
9.4.3	Agilidade Criptográfica em Camadas de Infraestrutura	35
10	CRISTALS KYBER	36
10.1	Introdução	36
10.2	Estrutura do CRYSTALS-Kyber	36
11	CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)	37
11.1	Definição e Objetivos da PQC	37
11.2	Paradigmas Matemáticos da PQC	37
11.3	Criptografia Baseada em Reticulados	37
11.4	Learning With Errors (LWE)	37
11.4.1	Implementação Didática em Java (Demonstração)	37
11.5	Padronização Pós-Quântica	37
12	A TRANSIÇÃO PARA PQC NO ECOSSISTEMA JAVA	38
12.1	Suporte à Criptografia Pós-Quântica no Java	38
12.2	Crypto-Agility	38
12.2.1	Implementação Prática: Demo de Crypto-Agility	38
12.3	Comparativo de Modelos	38
12.3.1	Implementação Prática: Benchmark Clássico vs. Kyber	38
13	DISCUSSÃO E ANÁLISE CRÍTICA	39
13.1	Impacto em Desempenho	39
13.2	Barreiras de Adoção	39
13.3	Implicações Sociais e Éticas	39
14	CONCLUSÃO	40
14.1	Síntese dos Resultados	40
14.2	Resposta ao Problema de Pesquisa	40
14.3	Trabalhos Futuros	40
	REFERÊNCIAS	41

4 Introdução

A onipresença da criptografia na infraestrutura digital moderna (internet, sistemas bancários, IoT e comunicações seguras).

4.1 Contextualização do Tema

Textos

4.2 Justificativa/Problema de Pesquisa

O conflito entre o determinismo computacional e a necessidade de aleatoriedade em sistemas criptográficos.

4.3 Motivação/Hipótese e Ameaça Tecnológica

O impacto da computação quântica — especialmente por meio do Algoritmo de Shor — sobre os modelos atuais de segurança e pseudoaleatoriedade.

4.4 Objetivos

Objetivo Geral: Analisar a evolução dos geradores pseudoaleatórios criptograficamente seguros frente à transição para a criptografia pós-quântica. Objetivos Específicos: Estudar PRNGs e CSPRNGs clássicos Analisar o impacto dos algoritmos quânticos Investigar os novos paradigmas de pseudoaleatoriedade baseados em reticulados Avaliar a adoção desses conceitos no ecossistema Java

4.5 Metodologia

Pesquisa bibliográfica, análise documental de padrões criptográficos e estudo prático no ecossistema Java.

5 FUNDAMENTOS DA ALEATORIEDADE EM COMPUTAÇÃO

5.1 Entropia e Fontes de Incerteza

Captação de eventos físicos imprevisíveis como base para sistemas criptográficos seguros.

Entropia é uma medida da aleatoriedade ou imprevisibilidade dos dados. No contexto da criptografia, a entropia é usada para gerar números aleatórios ou chaves que são essenciais para a comunicação segura e a criptografia. Sem uma boa fonte de entropia, os protocolos criptográficos podem se tornar vulneráveis a ataques que exploram a previsibilidade das chaves geradas.

Na maioria dos sistemas operacionais, a entropia é gerada pela coleta de eventos aleatórios de diversas fontes, como interrupções de hardware, movimentos do mouse, pressionamentos de teclas e atividade do disco. Esses eventos são inseridos em um conjunto de entropia, que é então usado para gerar números aleatórios quando necessário.

Protocolos criptográficos, como SSL/TLS, SSH e IPsec, dependem fortemente da entropia para gerar números aleatórios e chaves para criptografia, autenticação e proteção de integridade. A aleatoriedade desses números é crucial para a segurança da comunicação. Se um atacante conseguir prever os números aleatórios usados em um protocolo criptográfico, ele poderá comprometer a confidencialidade, a integridade ou a autenticidade da comunicação. Se a chave mestra prévia for previsível ou tendenciosa, um atacante poderá interceptar a mensagem criptografada, descriptografá-la e obter acesso às chaves de sessão. Isso permitiria ao atacante espionar a comunicação, modificar os dados ou se passar pelo servidor.

Um tipo de entropia. É a entropia de “Shannon”. Que utiliza um tratamento probabilístico de uma função logarítmica. Sendo sua formula:

$$H(X) = - \sum_{i=1}^n P(x_i) \log_b P(x_i) \quad (5.1)$$

Em que:

- $H(X)$ é a entropia em bits;
- p_i é a probabilidade de ocorrência do resultado i ;
- n é o número total de resultados possíveis.

Uma limitação determinística é em cima de um processador de maquina de estados finitos. Se acaso for utilizado as mesmas variáveis, o resultado permanece inalterado. Onde

se um invasor tiver a certeza da seed de origem da criptografia. Ela por si mesma, não é aleatória. Para evitar tais acontecimentos se faz necessário que o software faça a captação da incerteza do mundo físico.

A entropia deve ter força superior ou igual a segurança do sistema criptográfico. Entropia adicional poder ser necessária para compensar a perda de entropia durante o processo de geração de chaves, mas não necessariamente adiona mais segurança. Ter mais entropia do que a quantidade avaliada é aceitável, ter menos do que o recomendado pode ser fatal para a segurança do sistema criptográfico. O comprimento mínimo depende do mecanismo criptográfico específico e do nível de segurança desejado. A entrada de entropia e a seed resultante devem ser consistentes com a segurança dos dados protegidos pelo consumidor. Em um modelo DRBG a seed e as chaves geradas devem possuir o mesmo nível de segurança, pois no modelo DRBG depende da entropia usada, seguindo o critério de segurança crítico (CSP).

5.2 A Semente (Seed) como Elemento Crítico

Falar sobre esse ponto, pois vai ser utilizado na explicação dos protocolos tanto do funcionamento de verificação do NIST 800-22, do NIST IR 8547 e do NIST IR 7977 por quantico

Uma sequência de bits usada como entrada para um gerador de números pseudoaleatórios (DRBG). A semente é a chave inicial, usada internamente para a concepção do DRBG. Sua entropia deve ser suficiente para garantir a segurança do DRBG. A semente é um elemento crítico, pois determina a sequência de números pseudoaleatórios gerados pelo DRBG. Se a semente for previsível ou tiver baixa entropia, o DRBG pode ser vulnerável a ataques que exploram essa fraqueza. Portanto, é essencial que a semente seja gerada a partir de uma fonte de entropia confiável.

Uma sequência de bits usada como entrada para um mecanismo DRBG. A semente determinará uma parte do interior estado do DRBG, e sua entropia deve ser suficiente para apoiar a força de segurança do DRBG. Para obter uma seed suficientemente aleatória. Deve se submeter a uma estimativa de entropia para as saídas da fonte de ruído, baseada na própria fonte da entropia. Essa estimativa é denominada de $H_{\text{submitter}}$. Depois de possuir uma trilha de estimativas, a estimativa de entropia mínima por amostra chamada de H_{original} é determinada. Se o tamanho for superior a 256 bits, ele precisará ser reduzido para menor ou igual a 256 bits.

Se o conjunto de dados não for binário, é necessário uma entropia adicional em bit, denominada de $H_{\text{bitstring}}$ é estimada. O conjunto de dados sequências possui L amostras, cada uma contendo N bits e é considerado uma cadeia de bits de tamanho $L \times N$. Após os primeiros 1.000.000 bits podem vir a serem desconsiderados então $H_{\text{bitstring}}$ é calculada. Tendo como amostra estimada como $N \times H_{\text{bitstring}}$. A estimativa da entropia inicial da

fonte é calculada como $H_{\text{initial}} = \min(H_{\text{original}}, H_{\text{bitstring}})$.

5.3 Definição de Aleatoriedade e Tipos de Geradores Aleatórios

RNG (Random Number Generator) é um dispositivo ou algoritmo que gera uma sequência de números ou símbolos que não possuem nenhum padrão discernível, ou seja, são imprevisíveis. Que utiliza uma fonte de incerteza (ou seja, a fonte de entropia) ao mesmo tempo que faz uso de uma função de processo (processo de destilação) para gerar aleatoriedade. O processo de destilação é uma etapa crucial para exceder qualquer ruptura de segurança na origem da entropia que possa resultar em uma sequência não aleatória. Como a geração de longas sucessões de zeros ou uns, ou mesmo a repetição de um mesmo número, o que pode ser um indicativo de uma fonte de entropia comprometida. Normalmente a fonte de entropia é através de um processo físico, como o ruído térmico, circuito elétrico, o movimento do mouse ou a digitação do teclado, ou os efeitos quânticos de um semicondutor. Múltiplas fontes podem ser utilizadas para esse processo. As saídas de um RNG podem vir a ser utilizadas para um pseudo gerador de números aleatórios (PRNG). A saída de um RNG deve seguir certos critérios de aleatoriedade medidos por testes estatísticos, como os definidos pelo NIST 800-22, para garantir que os números gerados sejam adequadamente aleatórios para uso em criptografia e outras aplicações sensíveis à segurança. Para fins de criptografia, é crucial que os números gerados por um RNG sejam verdadeiramente aleatórios. No entanto, algumas das fontes como data/hora são previsíveis, que combinados com outras fontes de entropia, podem mitigar a previsibilidade. E que ainda pode se tornar deficiente ao passar pelos testes estatísticos. A produção de RNGs de alta qualidade se tornam um recurso oneroso. Tornando improdutivo quando se faz necessário de múltiplas gerações de RNGs. Por isso, a utilização de PRNGs se torna uma alternativa mais viável, pois eles podem gerar grandes quantidades de números pseudoaleatórios a partir de uma semente inicial.

PRNG (Pseudo-Random Number Generator) é um tipo de gerador de números aleatórios que utiliza um algoritmo determinístico para produzir uma sequência de números que aparenta ser aleatória. Ele faz uso de uma semente (seed) inicial para gerar uma sequência de números pseudoaleatórios. Em momentos que se faz necessário uso de imprevisibilidade, a seed se faz necessária ser imprevisível e oriundas e suma de um RNG. Por padrão um PRNG requer majoritariamente de um RNG. Como o PRNG é um algoritmo determinístico, por isso ele leva o nome de pseudoaleatório, pois a sequência de números gerada por um PRNG é completamente determinada pela semente inicial. Como a reprodução de uma sequência de números pseudoaleatórios é possível se a semente for conhecida, somente ela se faz necessária salvar e proteger. De forma cômica, muitos dos valores gerados por um PRNG aparentam ser mais aleatórios do que os números gerados por um RNG. Se sua concepção for bem desenvolvida, cada geração utiliza o valor da anterior por meio de

transformações matemáticas, que acabam introduzindo uma aleatoriedade adicional. Uma série de transformações podem eliminar autocorrelações e padrões, entre a entrada e a saída.

DRBG (Deterministic Random Bit Generator) é um tipo específico de PRNG que é projetado para ser criptograficamente seguro. Ele produz uma sequência de bits que a partir de uma seed inicial, determina uma sequência de bits pseudoaleatórios. A seed para instanciar um DRBG deve ser gerada a partir de uma fonte de entropia confiável, como um RBG (Random Bit Generator), para garantir a segurança do DRBG. Se a seed for protegida e tiver alta entropia, o DRBG pode ser considerado seguro para uso em criptografia. Além da dependência de uma semente de alta entropia, a segurança de um DRBG reside em sua capacidade de manter a Backtracking Resistance e a Prediction Resistance. Conforme o NIST SP 800-90A, esses mecanismos garantem que o comprometimento temporário do estado interno do gerador não resulte na exposição de chaves criptográficas geradas anteriormente ou no colapso da imprevisibilidade dos bits futuros

NRBG (Non-deterministic Random Bit Generator) é um tipo de gerador de números aleatórios que se baseia em processos físicos ou eventos imprevisíveis para gerar números aleatórios. Ao contrário dos DRBGs, que são determinísticos e dependem de uma semente para gerar números pseudoaleatórios, os NRBGs não são determinísticos e não dependem de uma semente. Eles podem usar fontes de entropia, como ruído térmico, fenômenos quânticos ou outros eventos físicos imprevisíveis para gerar números aleatórios.

TRNG (True Random Number Generator) utiliza da entropia de eventos físicos imprevisíveis para gerar números aleatórios ao invés da utilização de algoritmos determinísticos. É normalmente utilizado para gerar chaves criptográficas, Algoritmo de assinatura digital de curva elíptica[ECDSA] ou chaves MAC simétricas, para armazenar e transmitir dados com alta segurança em protocolos criptográficos como o TLS. As chaves geradas por um TRNG são altamente resistentes a ataques de força bruta, pois a entropia de um TRNG é geralmente muito alta, tornando difícil para um atacante adivinhar ou reproduzir as chaves geradas.

5.4 Avaliação Estatística da Aleatoriedade

Existem diversos testes estatísticos que podem ser utilizados em uma sequência para avaliar e comparar com uma sequência verdadeiramente aleatória. A aleatoriedade é uma característica probabilística, de forma que é possível descrever em termos de probabilidade. O resultado dos avaliadores estatísticos, quando baseados em uma sequência de bits verdadeiramente aleatória, é denominada de priori. É capaz de aplicar uma infinidade de testes estatísticos para avaliar a aleatoriedade de uma sequência de bits. Cada um avaliando um aspecto diferente da aleatoriedade, sendo a presença ou ausência de padrões, que sendo identificados seria uma indicação que a sequência não possui as características

aleatórias suficientes. Já que existe uma possibilidade de aplicar uma sequência infinita de testes, nenhum pode ser considerado completo, sendo necessário estabelecer um conjunto de testes estatísticos padronizados para avaliar a aleatoriedade de sequências de bits. E ainda assim devem ser analisados com cuidado para evitar conclusões errôneas sobre a aleatoriedade de uma sequência de bits.

Uma hipótese nula (H_0) é formulada para cada teste estatístico, que geralmente afirma que a sequência de bits é aleatória. Na outra ponta está a hipótese alternativa (H_1), que afirma que a sequência de bits não é aleatória. O teste estatístico é então aplicado à sequência de bits, e um valor de teste é calculado com base nos resultados do teste. Ao final de cada teste se tem uma decisão a ser tomada, que é se rejeitar ou não a hipótese nula.

Para cada distribuição teórica em cima da hipótese nula (H_0) é determinada por meios matemáticos. A partir disso, na distribuição de referência, um valor crítico é determinado longe o suficiente para que a probabilidade de obter um resultado tão extremo quanto o observado seja menor do que um nível de significância predefinido 0.01.

Na realização, se um valor de um teste exceder o valor crítico, a hipótese nula (H_0) é rejeitada. Se o pressuposto da aleatoriedade for verdadeira o valor final da estatística terá uma probabilidade muito baixa de exceder o valor crítico.

Só há duas alternativas de decisão, ou a hipótese nula (H_0) é rejeitada ou não é rejeitada. Se a hipótese nula for rejeitada, isso sugere que a sequência de bits não é aleatória, e que pode haver padrões ou correlações presentes na sequência. Se a hipótese nula (H_0) não for rejeitada, isso sugere que a sequência de bits é aleatória, mas não prova que a sequência é verdadeiramente aleatória.

Erro Tipo 1 ocorre quando a hipótese nula (H_0) é rejeitada, mesmo que seja verdadeira. Isso ocorre quando o teste estatístico indica que a sequência de bits não é aleatória. A probabilidade de um erro do tipo 1 é chamada de nível de significância e é denotada por α . Na criptografia valores comuns para α são 0.01 ou 0.001, o que significa que há uma probabilidade de 1% ou 0.1% de rejeitar a hipótese nula (H_0) quando ela é verdadeira. É esperado que 1 a cada 100 sequências de bits sejam rejeitadas.

Erro do Tipo 2 ocorre quando a hipótese nula (H_0) não é rejeitada, mesmo que seja falsa. Isso ocorre quando o teste estatístico indica que a sequência de bits é aleatória, mesmo que haja padrões ou correlações presentes na sequência. A probabilidade de um erro do tipo 2 é denotada por β . Não há um valor fixo para β , pois depende do teste estatístico específico e da natureza dos padrões ou correlações presentes na sequência de bits e que possui uma infinidade de maneiras de que uma sequência de bits não seja aleatória.

Uma das principais metas da execução de testes estatísticos é minimizar a probabilidade de cometer erros do tipo 2. Diminuindo a probabilidade de ter um gerador ruim aceitar uma sequência de bits como aleatória. O estatístico de teste é usado para calcular um

P-value que resume a força da evidência contra a hipótese nula.

Se $P\text{-value} = 1$, a sequência parece ter aleatoriedade perfeita.

Se $P\text{-value} = 0$, a sequência parece ser completamente não-aleatória.

Se $P\text{-value} \geq \alpha$, a hipótese nula é aceita (a sequência parece ser aleatória).

Se $P\text{-value} < \alpha$, a hipótese nula é rejeitada (a sequência não é aleatória).

O NIST SP 800–22 é um conjunto de testes estatísticos amplamente utilizado para avaliar a aleatoriedade de sequências de bits geradas por geradores de números aleatórios. Sendo ao todo 15 testes, cada um projetado para detectar diferentes tipos de padrões ou falhas na aleatoriedade. Esses testes incluem:

1. Teste de Frequência (monobit)
2. Teste de Frequência dentro de um bloco
3. Teste de Sequências
4. Testes para Maior Sequência de Uns em um bloco
5. Testes de Posto de Matriz Binária
6. Teste da Transformada Discreta de Fourier (Espectral)
7. Teste de Correspondência de Modelos não Sobrepostos
8. Teste de Correspondência de Modelos Sobrepostos
9. Teste "Estatístico Universal" de Maurer
10. Teste de Complexidade Linear
11. Teste Serial
12. Teste de Entropia Aproximada
13. Teste de Somas Cumulativas (Cusums)
14. Teste de Excursões Aleatórias
15. Teste de Variante de Excursões Aleatórias

6 Quebra de criptografias

6.1 Visão Geral da Quebra de Criptografias

A quebra de criptografia refere-se ao processo de comprometer a segurança de um sistema criptográfico, seja por meio da descoberta de vulnerabilidades, exploração de falhas ou desenvolvimento de técnicas que permitem a recuperação de informações protegidas sem autorização. A quebra pode ocorrer devido a falhas na implementação, fraquezas nos algoritmos ou avanços tecnológicos que tornam os métodos de ataque mais eficazes. A evolução da computação, especialmente com o advento da computação quântica, tem levantado preocupações significativas sobre a segurança dos sistemas criptográficos atuais, destacando a necessidade de desenvolver e adotar algoritmos resistentes a ataques futuros.

6.2 Falhas Históricas de Aleatoriedade

Dual_EC_DRBG, um gerador de números pseudoaleatórios que foi suspeito de conter uma backdoor, permitindo que um atacante previsse os números gerados.

DUAL_EC_DRBG (Dual Elliptic Curve Deterministic Random Bit Generator) é um fornecedor de dados pseudoaleatórios para iniciar e continuar a operação criptográfica. Seu uso começou em meados dos anos 2000. Ele utiliza duas curvas elípticas, P e Q , para gerar números pseudoaleatório, que são difíceis de prever o próximo valor ou os anteriores.

Curvas elípticas são uma curva algébrica definida por uma equação do tipo $y^2 = x^3 + ax + b$, onde a e b são constantes que satisfazem a condição de que a curva de não singularidade $4a^3 + 27b^2 \neq 0$. Elas são usadas em criptografia devido à sua estrutura matemática que permite operações eficientes e seguras, como a multiplicação de pontos, que é a base para muitos algoritmos criptográficos.

Utilizada em dispositivos moveis ou servidores que lidam com muitas conexões. Sendo corretamente implementada, é considerada segura quanto outras formas de criptografia. Ela é capaz de combinar de melhor eficiencia com segurança permitindo chaves menores do que as usadas em RSA, por exemplo, para um nível de segurança equivalente. Porém o Dual_EC_DRBG foi amplamente criticado por sua lentidão.

O Dual_EC_DRBG utiliza dois pontos, P e Q , em uma curva elíptica. Os valores pseudoaleatórios são gerados a partir da aritmética desses pontos; especificamente, ao utilizar o ponto P , é possível encontrar o seu dobro, $2P$, através da intersecção da reta tangente com a curva e posterior reflexão em relação ao eixo x . Esse processo de multiplicação escalar é perpetuado até atingir um ponto nP .

O algoritmo funciona utilizando um dado inicial (semente) s_i . O fluxo de geração segue os seguintes passos:

- **Atualização de Estado:** O novo estado interno é gerado ao computar o ponto $s_i P$, onde o valor da coordenada x resultante é definido como $s_{i+1} = x(s_i P)$.
- **Geração de Saída:** Simultaneamente, a saída é gerada através do ponto Q no processo $r_i = x(s_i Q)$.

Por padrão, são descartados os 16 bits mais significativos de r_i para compor a saída final utilizada na criptografia. Em termos de fluxo, o valor $s_i P$ impõe-se como o valor inicial para o próximo ciclo, enquanto $x(s_i Q)$ é o valor de saída. Para a segurança do gerador, não deve ser possível reverter s_i a partir da saída, nem que $s_i Q$ revele informações sobre o estado interno $s_i P$.

A vulnerabilidade do **Dual_EC_DRBG** reside justamente nos 16 bits truncados, que reduzem o espaço de busca para apenas $2^{16} = 65536$ possibilidades, tornando viável um ataque de força bruta para recuperar o ponto original. Caso exista uma relação especial entre os pontos tal que $P = zQ$, um atacante que conheça o escalar z pode deduzir, por meio de propriedades associativas, a seguinte igualdade:

$$z(s_i Q) = s_i(zQ) = s_i P$$

6.2.1 Uma avaliação pratica do Dual_EC_DRBG

Para a validação prática da vulnerabilidade, foi desenvolvida uma Prova de Conceito (PoC) em linguagem Java. A implementação utilizou a biblioteca Bouncy Castle para operações de criptografia de curva elíptica. O código fonte seguiu a estrutura lógica de implementações de referência disponíveis na comunidade de segurança sendo adaptado para demonstrar especificamente a previsibilidade de estados no ambiente Java 21.

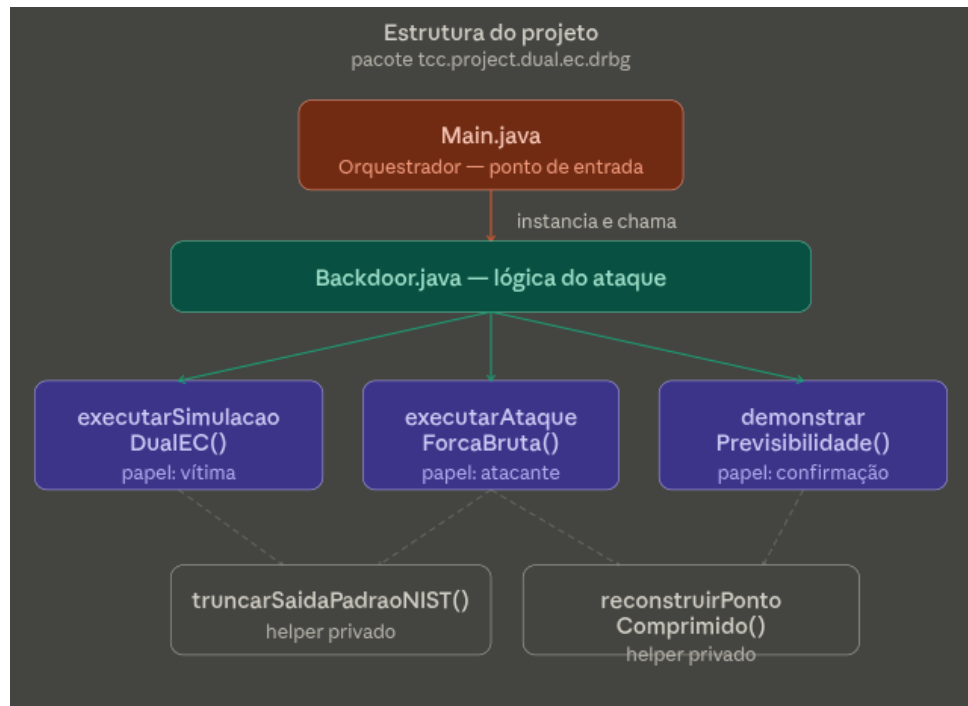
Tabela 1 – Dicionário de Variáveis da Classe Main

Variável	Tipo	Descrição Acadêmica
curve	X9ECParameters	Contém os parâmetros estruturais da curva elíptica NIST P-256.
P	ECPPoint	Ponto gerador base da curva, utilizado para a transição de estados internos (s_{i+1}).
n	BigInteger	A ordem da curva elíptica (número total de pontos no corpo finito).
d	BigInteger	O <i>Backdoor</i> . Escalar secreto tal que $Q = d \cdot P$.
Q	ECPPoint	Ponto público viciado inserido no gerador para permitir a criptoanálise.
e	BigInteger	Inverso multiplicativo de d em relação a n ($d^{-1} \pmod{n}$).
s	BigInteger	Semente (<i>seed</i>) secreta inicial que define a entropia do sistema.
r0Capturado	byte[]	Primeira amostra de saída (240 bits) observada pelo atacante.
s1Recuperado	BigInteger	O segredo interno descoberto após a execução do ataque de força bruta.

Tabela 2 – Dicionário de Métodos e Variáveis da Classe Backdoor

Identificador	Tipo	Descrição Técnica
executarSimulacao	Método	Implementa as funções de transição de estado e saída do Dual_EC_DRBG.
executarAtaque	Método	Algoritmo de busca exaustiva para recuperação de estado via <i>backdoor</i> .
s_state	BigInteger	Representa o estado interno atual (s_i) no ciclo do gerador.
totalTentativas	int	Contador do esforço computacional (máximo de 2^{17} operações).
xCandidate	BigInteger	Coordenada x reconstruída combinando bits adivinhados e bits observados.
compressionPrefix	String	Prefixo (02 ou 03) que resolve a ambiguidade da coordenada y na curva.
s1_candidate	BigInteger	Candidato a estado interno obtido pela aplicação do escalar e sobre o ponto.
truncarSaida	Método	Simula o descarte dos 16 bits mais significativos da coordenada x .
reconstruirPonto	Método	Formata a coordenada x para o padrão de decodificação da Bouncy Castle.

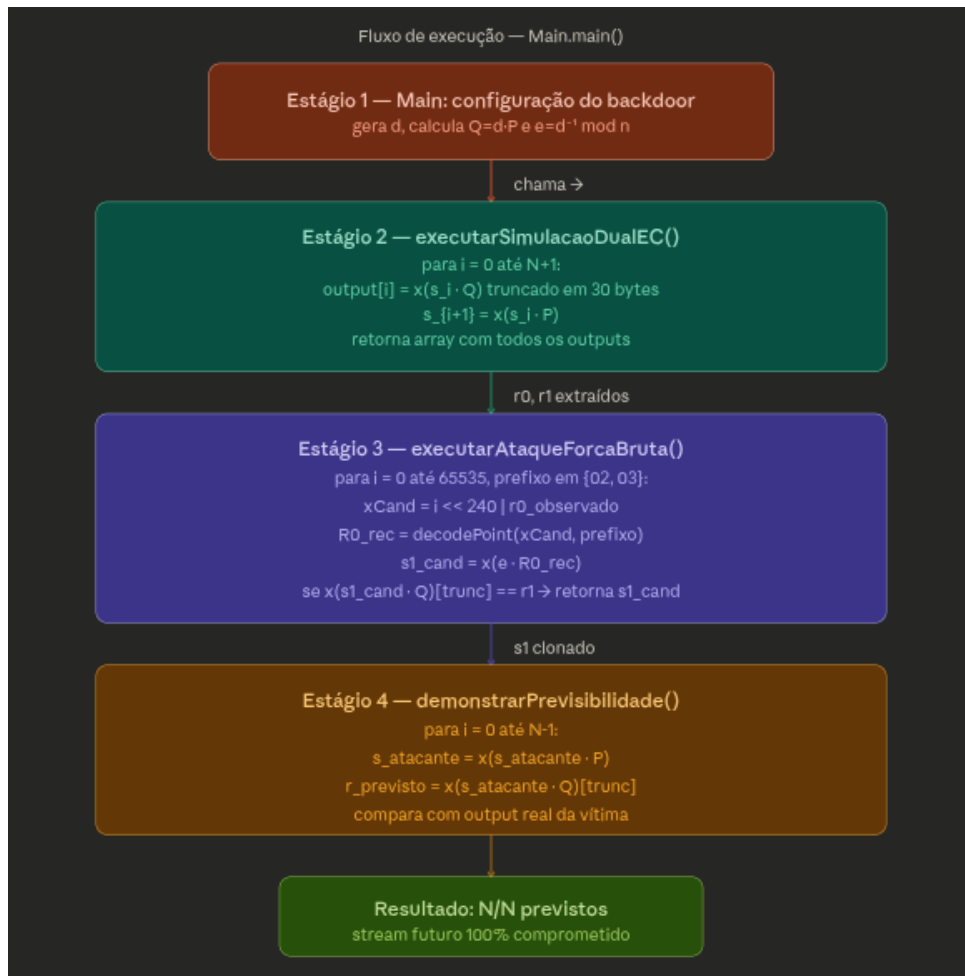
Figura 1 – Diagrama da Simulação do Backdoor do Dual_EC_DRBG



Fonte: Elaborado pelo autor (2026)

Diagrama é uma representação visual do processo de simulação do backdoor do Dual_EC_DRBG. Ele ilustra as etapas envolvidas na geração de números pseudoaleatórios e na execução do ataque de força bruta para recuperar o estado interno. Esse processo foi dividido entre a Main como orquestrador e a classe Backdoor, que contém a lógica de simulação e ataque, além de funções auxiliares. **Main:** Configura os parâmetros da curva elíptica, pontos P e Q, semente inicial e chama os métodos de simulação e ataque. **Backdoor:** Contém o método `executarSimulacaoDualEC` para simular a geração de números pseudoaleatórios e o método `executarAtaqueForcaBruta` para recuperar o estado interno a partir das saídas observadas. Ele também inclui funções auxiliares para reconstruir pontos e truncar saídas conforme o padrão NIST.

Figura 2 – Fluxo da Simulação do Backdoor do Dual_EC_DRBG



Fonte: Elaborado pelo autor (2026)

Um fluxo de execução é a ordem exata em que as instruções de um programa são processadas pelo computador. Diferente do fluxo original de funcionamento do DUAL_EC_DRBG, e como atacantes utilizam sua fragilidade. Na simulação todas as etapas foram implementadas e gerenciadas ao mesmo tempo, se conversando. Na realidade, essas funções e etapas não se conversam. O ataque começa com R_0 e R_1 (os dois outputs observados). O atacante não olha para R_2 durante o processo de quebra — ele prevê R_2 de forma independente, e só ao final compara com o valor real para confirmar que acertou. Isso é idêntico ao que aconteceria na vida real: o servidor TLS emite R_0 num handshake, R_1 num pacote seguinte, e R_2 em outro pacote posterior — todos trafegam pela rede, e o atacante os captura em sequência. R_2 já chegou pela rede antes mesmo de o atacante terminar o brute-force dos 16 bits.

Figura 3 – Simulação do Ataque de Força Bruta Teste 1

[illegible]

Fonte: Elaborado pelo autor (2026)

A comprovação prática da vulnerabilidade do Dual_EC_DRBG durante essa simulação demonstra de forma clara que após o atacante ter acesso aos dois primeiros outputs (R0 e R1), ele pode realizar um ataque de força bruta para recuperar o estado interno do gerador. E com isso ele consegue não só prever o R2, mas também todos os outputs futuros, comprometendo completamente a segurança do sistema que depende desse gerador para suas operações criptográficas.

Figura 4 – Simulação do Ataque de Força Bruta Teste 2

```

10 public class Main {
11     public static void main(String[] args) {
12         Backdoor backdoor = new Backdoor();
13         X9ECParameters curve = NISTNamedCurves.getByName("P-256");
14         ECPublicKey P = curve.getG();
15         BigInteger n = curve.getN();
16         BigInteger d = new BigInteger(256, new SecureRandom()).mod(n);
17         ECPublicKey Q = P.multiply(d).normalize();
18         BigInteger e = d.modInverse(n);
19         System.out.println("=== SIMULACAO DUAL_EC_DRBG - PREVISÃO DE GERACAO ===\n");
20         final int OUTPUTS_FUTUROS = 10;
21         BigInteger s = new BigInteger(256, new SecureRandom()).mod(n);
22         BigInteger[] estadosReais = new BigInteger(OUTPUTS_FUTUROS + 2);
23         byte[] outputResultado = backdoor.executarSimulacaoDualEC(OUTPUTS_FUTUROS, curve, P, Q, s, estadosReais);
24         byte[] rCapturado = outputResultado[0];
25         byte[] r1Capturado = outputResultado[1];
26         System.out.println("--- OUTPUTS OBSERVADOS PELO ATACANTE ---");
27         System.out.println("R0 (capturado): " + Hex.toHexString(rCapturado));
28         System.out.println("R1 (capturado): " + Hex.toHexString(r1Capturado));
29         System.out.println();
30         BigInteger sRecuperado = backdoor.executarAtaqueForçaBruta(rCapturado, r1Capturado, curve, Q, e);
31         backdoor.demonstrarPrevisibilidade(OUTPUTS_FUTUROS, sRecuperado, P, Q, outputResultado);
32     }
33 }

```

```

j@jenpop-os:~/Documents/Faeterj/TCCFaeterjPetrópolis$ cd /home/jen/Documents/Faeterj/TCCFaeterjPetrópolis ; /usr/bin/env /usr/lib/jvm/java-21-openjdk-amd64/bin/java @/tmp/cp_3r5o3hg8sjtac
=== SIMULACAO DUAL_EC_DRBG - PREVISÃO DE GERACAO ===

--- OUTPUTS OBSERVADOS PELO ATACANTE ---
R0 (capturado): c98bedd573a9d53f629d1b52bed733deb78e48c2ae818bdfb8c38df010
R1 (capturado): 3d4c7021972dc64b2e1818c2d94569377a8cf67c9597912bad8c7958c2b

--- EXECUTANDO CRIPTOMALISE (Brute-force 16-bits) ---
[!] Estado interno s1 sincronizado com sucesso!
[!] Esforço computacional: 104.265 tentativas.

--- PREDIÇÃO DE FLUXO DE DADOS (STREAM PREDICTION) ---
Output Valor Previsto pelo Atacante Status
R2 3341bcd7188dc1458e378bf56ff15c7ae415f79bdc2012b05d471fe79b1 [CONFIRMADO]
R3 91608b1354a6d0a7f525a272e2c23223a6d9d9d922172d0adfe223080c [CONFIRMADO]
R4 67ece1669e891da8321e50e74d267495fc57b753d7d5430247f0e5719a8c [CONFIRMADO]
R5 67b77a14a72db7a8877fcf435abc767867cd876c48befd775ce7d6d6f6 [CONFIRMADO]
R6 78a353ca4f63868272021644de01987b28ff7f1a99efa76cd015073a2 [CONFIRMADO]
R7 16d901c58ed435afe5daccb700094ba4c192eaa79b8bdab6f11d272aa [CONFIRMADO]
R8 fcc8a8665f514e492db16fe929b7348208eb95c79c8685db5e3195d4d3 [CONFIRMADO]
R9 c34f4e07c54cf6a8a32b4672f6e74db214682b6e4e0ba31e4b3960f7f [CONFIRMADO]
R10 90b849e2be5b086f38c82733b5a19982cef6e2043709314580e441120a0 [CONFIRMADO]
R11 78d628f7e1ebf5993dc4e61c6ee0b7b36ce6124448bc61fd39a3a4b7fc [CONFIRMADO]

Resultado da Predição: 10/10 acertos.

```

Fonte: Elaborado pelo autor (2026)

Apesar de o truncamento especificado pelo padrão NIST SP 800-90A remover apenas 16 bits da coordenada x , o custo efetivo do ataque de recuperação de estado é da ordem de 2^{17} multiplicações escalares. Isso ocorre porque, para cada candidato reconstruído de x , é necessário considerar ambas as possíveis coordenadas y , correspondentes às soluções par e ímpar da equação da curva elíptica. Formalmente, o custo total pode ser expresso como:

$$2^{16} \times 2 = 2^{17}$$

No experimento realizado, observou-se que a sincronização do estado exigiu 104.265 tentativas, valor consistente com o limite teórico máximo de 131.072 operações.

6.3 Vulnerabilidades em Algoritmos Criptográficos

Algoritmo de Grover. capaz de reduzir a força das entropias das seed pela metade: <https://learn.microsoft.com/es-es/azure/quantum/concepts-grovers> Algoritmo de Grover e a Semente: Explique que o ataque de Grover não "quebra" a matemática do AES ou da Seed, mas reduz a busca exaustiva. Se você usa uma semente de 128 bits, para um computador quântico ela tem o esforço de apenas 2^{64} . Por isso, o NIST IR 7977 exige o dobro de bits (256). Algoritmo de Shor: Este é o "assassino" do RSA e da Curva Elíptica. Enquanto o Grover reduz a força, o Shor aniquila o RSA completamente. É a razão principal da existência da Criptografia Pós-Quântica (PQC).

Colisões em SHA-1: Cite o projeto SHAttered (Google), que provou na prática que o SHA-1 é inseguro ao gerar dois arquivos PDF diferentes com o mesmo hash.

7 Revisão dos protocolos e padrões de criptografia

O NIST utiliza vários documentos para estabelecer os protocolos e padrões de criptografia, cada um com um propósito específico. Sendo comumente publicados em três categorias principais: FIPS (Federal Information Processing Standards), SPs (Special Publications) e IRs (Interagency Reports). Esses documentos são desenvolvidos para garantir a segurança e a integridade dos sistemas de informação, fornecendo diretrizes claras para a implementação de algoritmos criptográficos e práticas de segurança.

Vemos cada vez mais o crescimento do uso de computadores quânticos de forma substancial, o que tem levantando uma forte necessidade de desenvolver e padronizar algoritmos de criptografia pós-quântica (PQC) para proteger os dados contra ataques futuros. Pois nesse ritmo muitos criptossistemas atualmente considerados seguros entraram em fase de risco, incluindo sistemas de assinaturas digitais baseados em fatoração, logaritmos discretos e curvas elípticas(1). Em causa disso, teve uma intensidade das pesquisas em criptografia pós-quântica, resultando em uma variedade de esquemas candidatos para criptografia de chave pública, assinaturas digitais e funções de hash resistentes a ataques quânticos(1).

7.1 Fundamentação da Autoridade e Tipos de Padrões

7.1.1 NIST Internal/Interagency Reports (NISTIR)

Os documentos IRs são relatórios internos ou interagências que fornecem informações detalhadas sobre pesquisas, análises e avaliações relacionadas à criptografia(2). Eles documentam resultados de estudos e experimentos, servindo como fonte para pesquisadores sobre desafios e avanços na área(2).

7.1.2 FIPS

Os documentos FIPS são padrões de processamento de informações federais que estabelecem requisitos específicos para algoritmos criptográficos e práticas de segurança(2). Eles são desenvolvidos para garantir a interoperabilidade e a segurança dos sistemas de informação utilizados pelo governo dos Estados Unidos(2). Os FIPS são amplamente adotados por organizações governamentais e privadas como referência para a implementação de criptografia segura(2). Esses padrões abrangem uma variedade de tópicos, incluindo algoritmos de criptografia simétrica e assimétrica, funções de hash, e protocolos de segurança(2).

7.1.2.1 FIPS 204 (ML-DSA)

ML-DSA (Module-Lattice-Based Digital Signature Algorithm) é um padrão para assinaturas digitais pós-quânticas(3). Ele se baseia no CRYSTALS-Dilithium, onde se faz uso de problemas reticulados modulares (Module-LWE e Module-SIS)(3). Para cada nível de segurança o ML-DSA oferece níveis de proteção diferentes, sendo:(3)

- ML-DSA-44: Nível de Segurança de 128 bits para recursos limitados.
- ML-DSA-64: Nível de Segurança de 192 bits recomendado para a maioria dos casos.
- ML-DSA-84: Nível de Segurança de 256 bits longo prazo e alta segurança.

(3).

O ML-DSA é considerado suficientemente seguro e fortemente infalsificável, mesmo frente a ataques de computadores quânticos(3). Além de demonstrar a propriedade de não repúdio, ele foi desenvolvido de forma que, mesmo que o atacante conheça parte da chave privada, não consiga forjar uma assinatura adicional(3). A segurança baseia-se nos problemas LWE (Learning With Errors) e SIS (Short Integer Solution), expressos matematicamente como $As + e = b$ e $Ax \equiv 0 \pmod{q}$ (3).

A transição do CRYSTALS-Dilithium para o padrão final focou no fortalecimento da segurança(3):

- **Ajuste de Comprimento de Bits:** O comprimento de μ e ρ' foi aumentado para **512** bits.
- **Segurança de Assinatura:** Introdução de uma variante protegida utilizando a string ***rnd*** de **256** bits.

(3)

7.1.2.2 FIPS 205 (SLH-DSA)

SLH-DSA é um padrão para assinaturas digitais sem estado baseado em hash, fundamentado no SPHINCS+(4). A segurança “sem estado” é alcançada através de uma hiperárvore composta por camadas de árvores XMSS, integrando também os esquemas FORS e WOTS+(4).

7.1.3 SPs

Os documentos SPs são publicações especiais que fornecem diretrizes e recomendações para a implementação de algoritmos e práticas de segurança(2). Eles abordam tópicos como gerenciamento de chaves e avaliação de segurança(2).

7.1.3.1 FISMA e OMB

A FISMA estabelece o marco para a gestão da segurança em agências federais⁽²⁾. O OMB coordena a implementação dessas políticas e supervisiona a gestão de tecnologia da informação do governo⁽²⁾.

7.1.3.2 NIST SP 800–53

O NIST SP 800–53 fornece um catálogo abrangente de controles de segurança para sistemas federais⁽⁵⁾. O documento organiza os controles em 20 famílias.⁽⁵⁾

- AC (Access Control)
- AT (Awareness and Training)
- AU (Audit and Accountability)
- CA (Security Assessment and Authorization)
- CM (Configuration Management)
- CP (Contingency Planning)
- IA (Identification and Authentication)
- IR (Incident Response)
- MA (Maintenance)
- MP (Media Protection)
- PE (Physical and Environmental Protection)
- PL (Planning)
- PM (Program Management)
- PS (Personnel Security)
- PT (PII Processing and Transparency)
- RA (Risk Assessment)
- SA (System and Services Acquisition)
- SC (System and Communications Protection)
- SI (System and Information Integrity)
- SR (Supply Chain Risk Management)

(5)

7.2 Metodologia de Seleção

O NIST utiliza competições abertas como estratégia para padronizar primitivas criptográficas de última geração, envolvendo a comunidade internacional de pesquisa em um processo transparente e colaborativo(2). Pesquisadores do mundo inteiro podem participar ativamente, seja analisando requisitos, publicando estudos ou propondo algoritmos candidatos(2). Os autores selecionados recebem reconhecimento, mas abrem mão de direitos de propriedade intelectual para assegurar o uso livre de royalties(2). Durante o processo, o NIST estabelece critérios, promove workshops e divulga relatórios justificando as decisões de cada rodada, permitindo que a comunidade foque nos algoritmos mais promissores(2). Essa abordagem é especialmente eficaz quando não há consenso sobre a melhor solução ou quando novos esquemas exigem ampla criptoanálise(2).

7.2.1 Fases de Competição

Um processo típico de competição envolve chamadas públicas para requisitos, conferências de candidatos para revisar resultados de pesquisa (criptoanálise e desempenho) e “rodadas” de eliminação que permitem à comunidade focar esforços nos candidatos mais promissores até a seleção final(2).

O Processo de Padronização de Criptografia Pós-Quântica do NIST, iniciado em 2016, seguiu um modelo de competição pública dividido em rodadas de eliminação para selecionar algoritmos de assinaturas digitais e estabelecimento de chaves. A primeira rodada contou com 69 candidatos que atenderam aos critérios mínimos, seguidos por uma seleção de 26 algoritmos para a segunda rodada em 2019, baseada em análise de desempenho e feedback da comunidade. A terceira rodada, iniciada em 2020, focou em sete finalistas e oito suplentes, priorizando uma análise profunda da segurança teórica, evidências empíricas e avaliação comparativa para determinar os padrões finais.(1).

7.3 Manutenção e Substituição de Padrões

7.3.1 Ciclo de Vida e Retirada (Withdrawal)

Os padrões são revisados regularmente, com os FIPS sendo avaliados pelo menos a cada cinco anos(2). O processo de manutenção inclui a atualização ou a retirada do padrão, que pode ocorrer via ‘sunsetting’(2).

O NIST possui algumas etapas para a revisão e retirada de padrões, sendo eles:

- **Accepted:** O padrão em questão não possui riscos conhecidos.
- **Deprecated:** O padrão apresenta riscos conhecidos, mas ainda é considerado seguro para uso.

- **Legacy use:** O padrão pode somente ser usado em processamento de informações protegidas.
- **Disallowed:** O padrão não é mais considerado seguro e não deve ser usado.

(6).

O sunseting é um processo de retirada planejada, onde o NIST anuncia a descontinuação de um padrão com antecedência, permitindo que as organizações se preparem para a transição(6). Durante esse período, o padrão pode ser marcado como “deprecated” ou “legacy use”, indicando que ele ainda pode ser utilizado, mas com recomendações para migração futura(6).

8 Planejamento para a Criptografia Pós-Quântica (PQC)

8.1 Contextualização e Gestão de Risco

Esta seção introduz o problema e explica por que a transição deve ser planejada imediatamente, abordando o cenário de risco sob a ótica organizacional.

8.1.1 A Ameaça Quântica e o Paradigma “Harvest Now, Decrypt Later”

Conteúdo: Explicação sobre como adversários já estão coletando tráfego cifrado atual para quebrar a criptografia assim que computadores quânticos criptograficamente relevantes (CRQC) estiverem disponíveis.

Documento indicado: *NIST SP 1800-38A (Executive Summary)*. Fornece o panorama do problema e a urgência da migração sob a perspectiva do NCCoE.

Os avanços na computação quântica podem comprometer muitos dos algoritmos criptográficos atualmente amplamente utilizados para proteger informações digitais, tornando necessária a substituição dos algoritmos existentes por outros resistentes à computação quântica.⁽⁷⁾ Para auxiliar nesses esforços o NCCoE (National Cybersecurity Center of Excellence) está integrado com colaboradores do setor público e privado e organizações federais para desenvolver a migração, cenários de uso e arquiteturas de referência para a transição para a criptografia pós-quântica (PQC).

Muitos dos produtos, protocolos e serviços criptográficos usados atualmente, em particular aqueles que usam algoritmos de chave pública como o algoritmo Rivest-Shamir-Adleman (RSA), o algoritmo Diffie-Hellman de Curva Elíptica (ECDH) e o algoritmo de assinatura digital de curva elíptica (ECDSA), precisam ser atualizados, substituídos ou significativamente alterados¹⁸ para usar algoritmos resistentes à computação quântica. Muitos algoritmos de chave pública e os protocolos que os utilizam serão vulneráveis a ataques. A maioria dos sistemas de tecnologia da informação e comunicação atuais não foi projetada para suportar adaptações rápidas de novos algoritmos criptográficos sem fazer alterações significativas nos componentes dos sistemas.⁽⁷⁾

8.1.2 Mapeamento do Risco Quântico

Conteúdo: Como integrar a ameaça quântica nos processos de gestão de risco cibernético da organização.

Documento indicado: *NIST CSWP 48 (Cybersecurity White Paper)*. Relaciona a migração PQC com as práticas do *NIST Cybersecurity Framework (CSF)*.

A migração para algoritmos resistentes a ataques baseados em computação quântica é tratada como um componente essencial para manter a confidencialidade e integridade dos sistemas digitais. O NIST destaca que a implementação responsável dessas novas capacidades depende da adesão a controles de segurança já estabelecidos em frameworks de risco, como o NIST CSF 2.0 e o NIST SP 800-53(8)

Para que o mapeamento de risco seja eficaz, o documento estabelece que a organização deve visualizar a migração através de componentes de arquitetura lógica divididos em duas frentes principais:

- **Descoberta e Inventário:** Incluem ferramentas de coleta de dados criptográficos, ferramentas de inventário, ferramentas analíticas e gestão de ciclo de vida de certificados
- **Agilidade Criptográfica e Novos Padrões:** Envolvem implementações de algoritmos quantum-ready, serviços criptográficos, plugins de integração, autoridades certificadoras e Módulos de Segurança de Hardware (HSMs).

(8)

A integração da ameaça quântica nos processos de gestão de risco não é apenas uma substituição de algoritmos, mas uma relação funcional de suporte mútuo definida por:

- **Supports:** O componente PQC auxilia na obtenção de um resultado de segurança ou controle específico.
- **Is Supported By:** O componente PQC depende de controles existentes para operar de forma confiável.

(8)

Estas interações podem ser classificadas como:

- **Partially Supports:** O componente PQC contribui para alcançar o resultado de segurança desejado, mas não é suficiente por si só.
- **Depends On:** O componente PQC tem uma dependência crítica em um controle específico para funcionar corretamente.

(8)

- **Example of:** Onde o conceito de suporte exemplificado alcança parcialmente o resultado de segurança desejado.
- **Integral to:** O componente PQC é fundamental para alcançar o resultado de segurança desejado.

- **Precedes:** O componente PQC deve ser implementado antes de outros componentes para garantir a segurança.

(8)

O mapeamento demonstra como as capacidades PQC sustentam os resultados do CSF:

- **Gerenciamento de Ativos (ID.AM):** As ferramentas de coleta de dados são pré-requisitos (Precedes) para manter inventários de hardware (ID.AM-01), software (ID.AM-02) e dados (ID.AM-07), pois o inventário criptográfico é necessário para entender a adequação contínua dos serviços de segurança.
- **Avaliação de Risco (ID.RA):** Ferramentas analíticas identificam fraquezas e lacunas de conformidade quântica, servindo como exemplo (Example of) para a identificação e registro de vulnerabilidades em ativos (ID.RA-01).
- **Segurança de Dados (PR.DS):** A implementação de algoritmos e HSMs quantum-ready protege a confidencialidade e integridade de dados em repouso (PR.DS-01) e em trânsito (PR.DS-02) contra a ameaça de descriptografia futura.

(8)

Para uma gestão detalhada, o risco quântico deve ser mapeado em controles específicos de segurança e privacidade:

- **CM-8 (Inventário de Componentes):** A descoberta criptográfica é integral para identificar componentes em subsistemas complexos, especialmente onde a criptografia está embutida em bibliotecas ou processos de execução.
- **SC-12 (Estabelecimento e Gestão de Chaves):** O uso de ferramentas analíticas permite identificar casos onde algoritmos vulneráveis de transporte e estabelecimento de chaves ainda estão em uso ou podem ser selecionados por erro de configuração.
- **CP-2 (Plano de Contingência):** O inventário de ativos criptográficos críticos é um passo necessário para informar o desenvolvimento de planos de contingência, permitindo a priorização da substituição de componentes legados.
- **SA-4 (Processo de Aquisição):** A migração exige que requisitos funcionais de segurança pós-quântica e força de mecanismo sejam incluídos em contratos de aquisição de novos sistemas e serviços.

(8)

A integração do risco quântico permite que a organização utilize suas políticas de risco existentes (GV.PO-01) para constranger e guiar a seleção de bibliotecas e algoritmos.(8) Isso transforma a migração PQC de um desafio puramente técnico em uma atividade de conformidade e governança, assegurando que os novos sistemas sejam implementados de acordo com a estratégia de segurança organizacional.

8.2 Inventário e Descoberta Criptográfica

Antes de migrar, uma organização precisa saber o que possui. Esta seção detalha as metodologias para rastrear o uso atual de criptografia.

8.2.1 Estratégias de Descoberta em Redes e Sistemas

Conteúdo: Métodos e ferramentas para varrer infraestruturas, encontrar chaves embutidas em código, protocolos obsoletos e certificados ocultos.

Documento indicado: *NIST SP 1800-38B (Discovery for PQC Migration)*. Fornece cenários práticos e arquiteturas de referência para a fase de descoberta.

8.2.2 Adoção do CBOM (Cryptographic Bill of Materials)

Conteúdo: O conceito de catalogar a criptografia de forma padronizada para monitorar vulnerabilidades em cadeias de suprimentos de software.

Documento indicado: *NIST SP 1800-38B*. Aborda diretamente como gerar e manter inventários de ativos criptográficos.

8.3 Agilidade Criptográfica e Novos Padrões

Aborda o planejamento arquitetural necessário para facilitar atualizações e apresenta as novas ferramentas de proteção.

8.3.1 Conceitos de Agilidade e Desafios de Desempenho

Conteúdo: O que significa projetar um sistema ágil e quais são os impactos reais na rede (latência, tamanho de chaves, largura de banda) ao trocar os algoritmos.

Documento indicado: *NIST SP 1800-38C (Interoperability and Performance)*. Apresenta casos de uso reais e testes de impacto.

8.3.2 Os Padrões Pós-Quânticos Finais

Conteúdo: A especificação técnica e a indicação de uso dos algoritmos selecionados.
Documentos indicados:

- **FIPS 203 (ML-KEM):** Para troca de chaves criptográficas.
- **FIPS 204 (ML-DSA) e FIPS 205 (SLH-DSA):** Para assinaturas digitais.
- **NIST IR 8413:** Para critérios técnicos do Round 3.

8.4 Estratégias de Migração e Hibridização

Foca na parte prática e operacional da transição.

8.4.1 Hibridização (Criptografia Clássica e PQC)

Conteúdo: A abordagem recomendada de usar algoritmos clássicos em conjunto com PQC durante o período de transição.

Documento indicado: *NIST SP 1800-38C*. Discute os protocolos que suportam negociação híbrida.

8.4.2 Assinaturas Baseadas em Hash para Adoção Imediata

Conteúdo: Uso de algoritmos de assinatura que já são considerados seguros contra ataques quânticos, úteis para validar firmware.

Documento indicado: *NIST SP 800-208*. Padrões stateful hash-based (LMS e XMSS).

8.5 Roadmap e Manutenção da Base Criptográfica

Conclui o planejamento com prazos normativos e a importância de elementos basilares da criptografia.

8.5.1 Cronograma e Descontinuação de Algoritmos Atuais

Conteúdo: Prazos para que algoritmos de chaves públicas atuais (como RSA-2048) deixem de ser considerados seguros.

Documento indicado: *NIST SP 800-131A Rev. 3*. Estipula o ciclo de vida e os prazos limite.

8.5.2 O Papel Contínuo da Entropia

Conteúdo: A garantia de que a segurança fundamental ainda depende da geração de números aleatórios de alta qualidade (RNG).

Documento indicado: *NIST SP 800-22*. Conecta os testes de aleatoriedade como pré-requisito indispensável.

9 NIST IR 8547 Transição para a Criptografia Pós-Quântica: Estratégias e Considerações

9.1 Urgencia Prática e o Modelo de Ameaça

O modelo de ameaça é uma ferramenta essencial para a segurança cibernética, permitindo que as organizações identifiquem, compreendam e mitiguem ameaças potenciais. Ele ajuda a priorizar os recursos de segurança, focando nas ameaças mais relevantes e perigosas. O modelo de ameaça é fundamental para o desenvolvimento de estratégias eficazes de defesa cibernética, garantindo que as organizações estejam preparadas para enfrentar os desafios atuais e futuros.

9.1.1 Ameaça Harvest now, Decrypt Later

A ameaça "Harvest now, Decrypt Later" refere-se à prática de coletar dados criptografados agora, com a intenção de descriptografá-los no futuro, quando os recursos computacionais ou as vulnerabilidades de segurança permitirem. Essa ameaça é particularmente preocupante para dados sensíveis que precisam ser protegidos por longos períodos, como informações pessoais, financeiras e de saúde. Para mitigar essa ameaça, é crucial adotar práticas de criptografia robustas e atualizadas, além de monitorar continuamente as vulnerabilidades e avanços tecnológicos que possam impactar a segurança dos dados.

9.1.2 Teorema de Mosca e a Linha do Tempo

O Teorema de Mosca é um conceito fundamental na segurança cibernética que destaca a importância de considerar o tempo ao avaliar ameaças e vulnerabilidades. Ele sugere que, para proteger adequadamente os sistemas, é necessário entender não apenas as ameaças atuais, mas também as ameaças futuras que podem surgir à medida que a tecnologia evolui. A linha do tempo é uma ferramenta útil para visualizar e planejar a defesa contra ameaças, permitindo que as organizações antecipem e se preparem para possíveis ataques futuros, garantindo uma postura de segurança proativa.

9.2 Novos Padrões e Categorias de Segurança

A evolução dos padrões de segurança é crucial para enfrentar as ameaças cibernéticas em constante mudança. Novos padrões e categorias de segurança são desenvolvidos para abordar as vulnerabilidades emergentes e garantir a proteção eficaz dos sistemas e dados. A adoção de padrões atualizados é essencial para manter a resiliência contra ataques

cibernéticos, promovendo uma abordagem de segurança mais robusta e adaptável às novas ameaças.

9.2.1 Publicações dos primeiros FIPS PQC

As publicações dos primeiros FIPS (Federal Information Processing Standards) para criptografia pós-quântica (PQC) representam um marco importante na evolução da segurança cibernética. Esses padrões são desenvolvidos para garantir que os sistemas de criptografia sejam resistentes a ataques de computadores quânticos, que têm o potencial de quebrar os métodos de criptografia tradicionais. A adoção desses padrões é crucial para proteger dados sensíveis e garantir a segurança a longo prazo, especialmente à medida que a tecnologia quântica avança e se torna mais acessível.

9.2.2 Categorias de Segurança Pós-Quântica (1 a 5)

As categorias de segurança pós-quântica são classificações que ajudam a identificar e categorizar os diferentes tipos de algoritmos de criptografia que são resistentes a ataques de computadores quânticos. Essas categorias incluem algoritmos baseados em reticulados, códigos, multivariados, hash-based e isogenias, cada um com suas próprias características e níveis de segurança. A compreensão dessas categorias é essencial para escolher os algoritmos mais adequados para proteger dados sensíveis contra ameaças futuras, garantindo uma postura de segurança robusta e resiliente.

9.3 Cronograma de Descontinuação (Deprecation)

O cronograma de descontinuação é um plano estratégico que define o processo e os prazos para a retirada de sistemas, tecnologias ou práticas de segurança obsoletas. Ele é essencial para garantir uma transição suave e segura para novas soluções, minimizando os riscos associados à manutenção de sistemas vulneráveis ou desatualizados. A implementação de um cronograma de descontinuação eficaz ajuda as organizações a se adaptarem às mudanças tecnológicas e a manterem uma postura de segurança proativa, garantindo a proteção contínua dos dados e sistemas.

9.3.1 Transição de Assinaturas Digitais (RSA, ECDSA, EdDSA)

A transição de assinaturas digitais, como RSA, ECDSA e EdDSA, é um processo crucial para garantir a segurança dos sistemas de criptografia à medida que novas ameaças emergem. Com o avanço da tecnologia, especialmente a computação quântica, é necessário migrar para algoritmos de assinatura digital mais robustos e resistentes a ataques futuros. A adoção de novos algoritmos de assinatura digital é essencial para proteger a integridade e

autenticidade dos dados, garantindo a segurança a longo prazo em um ambiente cibernético em constante evolução.

9.3.2 Transição de Estabelecimento de Chaves (DH, MQV, RSA)

A transição de estabelecimento de chaves, como DH (Diffie-Hellman), MQV (Menezes-Qu-Vanstone) e RSA, é um processo fundamental para garantir a segurança das comunicações criptografadas. Com o avanço da tecnologia, especialmente a computação quântica, é necessário migrar para algoritmos de estabelecimento de chaves mais robustos e resistentes a ataques futuros. A adoção de novos algoritmos de estabelecimento de chaves é essencial para proteger a confidencialidade e integridade das comunicações, garantindo a segurança a longo prazo em um ambiente cibernético em constante evolução.

9.4 Estratégias de Transição: Protocolos Híbridos

As estratégias de transição, como os protocolos híbridos, são abordagens que combinam algoritmos de criptografia tradicionais com algoritmos pós-quânticos para garantir a segurança durante o processo de migração. Esses protocolos permitem que as organizações mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à transição. A implementação de protocolos híbridos é uma estratégia eficaz para garantir a proteção contínua dos dados e sistemas durante a evolução da tecnologia, proporcionando uma transição suave e segura para o futuro da segurança cibernética.

9.4.1 Soluções Híbridas (PQC-Classical)

As soluções híbridas, que combinam algoritmos de criptografia pós-quântica (PQC) com algoritmos clássicos, são uma abordagem estratégica para garantir a segurança durante a transição para novas tecnologias de criptografia. Essas soluções permitem que as organizações mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à migração. A implementação de soluções híbridas é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

9.4.2 Protocolos Híbridos (TLS, SSH, IPsec)

Os protocolos híbridos, como TLS (Transport Layer Security), SSH (Secure Shell) e IPsec (Internet Protocol Security), são abordagens que combinam algoritmos de criptografia tradicionais com algoritmos pós-quânticos para garantir a segurança durante a transição para novas tecnologias de criptografia. Esses protocolos permitem que as organizações

mantenham a compatibilidade com sistemas legados enquanto adotam novas soluções de segurança, minimizando os riscos associados à migração. A implementação de protocolos híbridos é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

9.4.3 Agilidade Criptográfica em Camadas de Infraestrutura

A agilidade criptográfica em camadas de infraestrutura é uma abordagem que permite a flexibilidade na escolha e implementação de algoritmos de criptografia em diferentes camadas de um sistema. Essa abordagem é crucial para garantir a segurança durante a transição para novas tecnologias de criptografia, permitindo que as organizações adotem soluções híbridas e se adaptem às mudanças nas ameaças cibernéticas. A implementação da agilidade criptográfica em camadas de infraestrutura é essencial para proteger os dados e sistemas durante a evolução da tecnologia, garantindo uma transição suave e segura para o futuro da segurança cibernética.

10 Crystals Kyber

10.1 Introdução

O CRYSTALS-Kyber é um sistema de criptografia de chave pública baseado em problemas de aprendizado com erros (LWE) e é considerado resistente a ataques de computadores quânticos. Ele é parte do projeto CRYSTALS (Cryptographic Suite for Algebraic Lattices) e é um dos candidatos para o padrão de criptografia pós-quântica do NIST (National Institute of Standards and Technology). O CRYSTALS-Kyber é projetado para ser eficiente em termos de tempo de execução e tamanho de chave, tornando-o uma opção viável para aplicações práticas de criptografia pós-quântica.

10.2 Estrutura do CRYSTALS-Kyber

O CRYSTALS-Kyber é baseado em um esquema de criptografia de chave pública que utiliza matrizes e vetores para realizar operações de criptografia e descriptografia. Ele é composto por três algoritmos principais: geração de chaves, criptografia e descriptografia.

11 CRIPTOGRAFIA PÓS-QUÂNTICA (PQC)

11.1 Definição e Objetivos da PQC

Algoritmos clássicos projetados para resistir a ataques quânticos.

11.2 Paradigmas Matemáticos da PQC

Reticulados, códigos corretores de erro, funções hash e isogenias.

11.3 Criptografia Baseada em Reticulados

Introdução ao conceito de Lattices como base da nova segurança criptográfica.

11.4 Learning With Errors (LWE)

Fundamento matemático da pseudoaleatoriedade pós-quântica.

11.4.1 Implementação Didática em Java (Demonstração)

Implementação simplificada do LWE do zero em Java para fins didáticos, mostrando como o erro intencional funciona matematicamente antes de utilizar a biblioteca pronta.

11.5 Padronização Pós-Quântica

O papel do ML-KEM (Kyber) e o processo de padronização conduzido pelo NIST.

12 A TRANSIÇÃO PARA PQC NO ECOSSISTEMA JAVA

12.1 Suporte à Criptografia Pós-Quântica no Java

Evolução do JDK e integração de algoritmos pós-quânticos em versões modernas (Java 21+).

12.2 Crypto-Agility

Boas práticas para desenvolvimento de sistemas criptográficos flexíveis e preparados para mudanças de algoritmo.

12.2.1 Implementação Prática: Demo de Crypto-Agility

Criação de uma interface Java que abstrai o algoritmo de geração de chaves, permitindo trocar de RSA para Kyber alterando apenas a configuração — sem reescrever o código da aplicação.

12.3 Comparativo de Modelos

Geração de chaves e aleatoriedade no modelo clássico versus modelo baseado em reticulados (Module-Lattice).

12.3.1 Implementação Prática: Benchmark Clássico vs. Kyber

Benchmark comparativo entre `java.security.SecureRandom` clássico e ML-KEM (Kyber) via Bouncy Castle, medindo tempo de geração de chaves, uso de memória e throughput. Inclui comparativo de tamanho de chaves entre RSA-2048 e Kyber. Nota: Confirmar com o orientador o uso da biblioteca Bouncy Castle como dependência, por ser a opção mais acessível para PQC em Java atualmente.

13 DISCUSSÃO E ANÁLISE CRÍTICA

13.1 Impacto em Desempenho

Custos computacionais, consumo de memória e latência — baseados nos resultados do benchmark da seção 6.3.1.

13.2 Barreiras de Adoção

Sistemas legados, limitações de hardware e resistência organizacional.

13.3 Implicações Sociais e Éticas

Soberania de dados, privacidade, vigilância e assimetria tecnológica.

14 CONCLUSÃO

14.1 Síntese dos Resultados

A inevitabilidade da transição criptográfica.

14.2 Resposta ao Problema de Pesquisa

A evolução da pseudoaleatoriedade como pilar da segurança pós-quântica.

14.3 Trabalhos Futuros

Geradores Quânticos de Números Aleatórios (QRNG) e integração híbrida TRNG + PQC.

Referências

- 1 National Institute of Standards and Technology. *NIST Post-Quantum Cryptography Standardization Process*. Gaithersburg, MD, 2023. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8413-upd1.pdf>>.
- 2 National Institute of Standards and Technology. *NIST Cryptographic Standards and Guidelines Development Process*. Gaithersburg, MD, 2016.
- 3 National Institute of Standards and Technology. *FIPS PUB 204 Transitioning to Post-Quantum Cryptography*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.204.pdf>>. Acesso em: 23 abr. 2026.
- 4 National Institute of Standards and Technology. *FIPS PUB 205 Transitioning to Post-Quantum Cryptography: Implementation and Operational Considerations*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.205.pdf>>. Acesso em: 23 abr. 2026.
- 5 National Institute of Standards and Technology. *NIST Special Publication 800-53 Revision 5*. Gaithersburg, MD, 2020. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>. Acesso em: 23 abr. 2026.
- 6 National Institute of Standards and Technology. *NIST Special Publication 800-131A Revision 2*. Gaithersburg, MD, 2019. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-131Ar2.pdf>>.
- 7 National Institute of Standards and Technology. *NIST SP 1800-38A: Post-Quantum Cryptography Migration*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication1800-38a.pdf>>.
- 8 National Institute of Standards and Technology. *NIST Cybersecurity White Paper 48: Post-Quantum Cryptography*. Gaithersburg, MD, 2024. Disponível em: <<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.48.ipd.pdf>>.